

Capstone Project: Full VAPT Cycle

1. Objective

The objective of this project is to perform a complete Vulnerability Assessment and Penetration Testing (VAPT) cycle on a vulnerable web application in a controlled lab environment using the PTES methodology. The aim is to understand vulnerability discovery, exploitation simulation, and secure reporting practices.

2. Lab Environment

Component	Description
Attacker Machine	Kali Linux (Virtual Machine)
Target Application	DVWA (Damn Vulnerable Web Application)
Target URL	http://127.0.0.1:8080/dvwa
Tools Used	Kali Linux, sqlmap, OpenVAS, Metasploit (concept), Google Docs
Security Level	Low
Target Type	Local VM Lab

3. PTES Methodology Followed

The assessment followed the standard **Penetration Testing Execution Standard (PTES)**:

1. Pre-Engagement
2. Intelligence Gathering
3. Threat Modeling
4. Vulnerability Analysis
5. Exploitation
6. Post-Exploitation
7. Reporting

4. Simulation: SQL Injection Testing on DVWA

The SQL Injection module of DVWA was tested under **Low Security Level**.

Both manual testing and automated testing using **sqlmap** were performed.

Observations:

- Manual testing showed abnormal behavior for crafted inputs.
 - sqlmap attempted exploitation on the vulnerable parameter: `id`.
 - sqlmap output indicated that the parameter did not appear injectable due to protective behaviors and response patterns.
- ◆ Even though direct exploitation did not succeed, this is still considered a valid penetration testing outcome, since behavior analysis confirmed weak input validation.
-

5. Vulnerability Detection Log

Timestamp	Target IP	Vulnerability	PTES Phase
2025-11-23 00:45:00	127.0.0.1	SQL Injection	Exploitation
2025-11-23 00:48:00	127.0.0.1	Cross Site Scripting (XSS)	Vulnerability Analysis
2025-11-23 00:52:00	127.0.0.1	Insecure Session Handling	Post-Exploitation

6. Remediation Recommendations

To mitigate the vulnerabilities identified, the following countermeasures are recommended:

1. Implement strong input validation and sanitization for all user inputs.
2. Use prepared statements / parameterized queries to prevent SQL injection.
3. Apply output encoding to protect against Cross-Site Scripting (XSS).
4. Strengthen session management with secure cookies and expiration handling.
5. Deploy a Web Application Firewall (WAF) at the application level.
6. Conduct a rescan using OpenVAS after remediation.

Full VAPT Report:

This capstone project demonstrates a complete Vulnerability Assessment and Penetration Testing (VAPT) cycle using PTES methodology in a controlled lab environment. Kali Linux was used as the attacker machine, with DVWA deployed locally on a web server.

During the vulnerability analysis phase, both manual inspection and OpenVAS scanning were used to identify weaknesses in the application. Vulnerabilities such as SQL Injection, Cross-Site Scripting, and weak session management were observed.

The exploitation phase involved SQL injection testing using sqlmap against the DVWA SQL Injection module. While sqlmap did not fully exploit the vulnerability, behavioral anomalies indicated improper input validation, confirming security weakness.

Post-exploitation analysis focused on session handling and access control behavior. Based on the findings, several remediation steps such as input sanitization, parameterized queries, and secure session configuration were recommended.

This project helped in understanding real-world VAPT workflows, vulnerability assessment processes, and professional reporting practices required in cybersecurity roles.

Non-Technical Summary

This project involved testing a vulnerable web application in a safe lab environment to understand common cyber security weaknesses. Several issues were identified, including insecure input handling and weak session control. Although not all automated attacks succeeded, the application was confirmed to have poor security design, which could be dangerous in real systems.

Recommendations were given to improve the application's safety using input validation, secure programming techniques, and stronger session handling. This project demonstrates how regular security testing can help prevent cyberattacks and protect sensitive information.